

Cyber Threat Intelligence

Executive Briefing

Report Date: June 30, 2026

Generated: 2026-06-30 14:43 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
0	11	8	1	20

2. Executive Summary

As of June 30, 2026, the security intelligence unit has concluded an assessment of 20 identified vulnerabilities, categorized by a severity distribution of 0 Critical, 11 High, 8 Medium, and 1 Low. The organization's current risk posture is characterized as Elevated, necessitated by the presence of multiple High-severity vulnerabilities that require immediate remediation to prevent potential unauthorized system access and remote code execution. CVE-2026-55698 (Lockfile Resolution Hijacking in pnpm) represents the most significant threat, as it permits the subversion of internal development pipelines, thereby threatening the integrity of the software supply chain. Consequently, the organization must adopt an aggressive defensive posture, prioritizing the immediate patching of these vulnerabilities to mitigate exposure to persistent threat actors. Leadership is advised to authorize immediate resource reallocation to support the rapid deployment of these critical security updates.

3. Critical Action List

- Immediate patching of CVE-2026-55698 in all pnpm-reliant build environments within 24 hours.
- Remediate the arbitrary file write vulnerability in gonic (CVE-2026-49340) by enforcing strict input validation within 48 hours.
- Implement the patch for CVE-2026-47424 to secure the OpenAM Groovy sandbox environment by close of business, July 1, 2026.
- Apply vendor-issued patches for CVE-2026-55697 to mitigate pnpm repository configuration risks within 72 hours.
- Address CVE-2026-55487 by validating manifest identities and updating build controls within 72 hours.
- Conduct comprehensive auditing and remediation of remaining six High-severity findings by July 5, 2026.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
--------	--------------	------	----------	---------	-----

CVE-2026-55698	Lockfile Resolution Hijacking in ...	8.8	High	89/100	CWE-345
CVE-2026-49340	Arbitrary File Write in gonic	8.1	High	83/100	CWE-22
CVE-2026-47424	RCE via Groovy Sandbox Escape in ...	8.8	High	79/100	CWE-693
CVE-2026-55697	Remote Command Execution via pnpm...	7.5	High	78/100	CWE-78
CVE-2026-55487	Manifest Spoofing for Arbitrary L...	7.5	High	78/100	CWE-346
CVE-2026-55700	Arbitrary File Write in pnpm Stage	7.1	High	74/100	CWE-22
CVE-2026-49338	IDOR in Subsonic API Playlist Acc...	7.1	High	74/100	CWE-285
CVE-2026-49339	Path Traversal in gonic Playlist ...	7.1	High	74/100	CWE-22
CVE-2026-48717	OAuth Authorization Bypass via PK...	8.1	High	73/100	CWE-285
CVE-2026-53523	Host Header Injection in Nezha OA...	6.8	Medium	71/100	CWE-601
CVE-2026-55699	Local File Deletion via pnpm Bin ...	6.5	Medium	69/100	CWE-22
CVE-2026-53522	WebSocket Resource Exhaustion in ...	6.5	Medium	69/100	CWE-770
CVE-2026-44840	DQL Injection in Dgraph GraphQL Q...	7.5	High	68/100	CWE-943
CVE-2026-47426	OAuth Client Impersonation via JW...	7.5	High	68/100	CWE-287
CVE-2026-53465	Heap Overflow in ImageMagick SF3 ...	6.2	Medium	66/100	CWE-122
CVE-2026-55180	Environment Secret Exfiltration v...	6.5	Medium	59/100	CWE-200
CVE-2026-54243	CSV Formula Injection in Statamic	6.1	Medium	55/100	CWE-1236
CVE-2026-53464	Memory Leak in ImageMagick Wand P...	4.0	Medium	46/100	CWE-401
CVE-2026-54242	SSRF via DNS Rebinding in Statamic	4.9	Medium	44/100	CWE-367
CVE-2026-54244	Unauthorized Preview Access in St...	3.5	Low	27/100	CWE-863

5. Detailed Vulnerability Findings

CVE-2026-55698

Finding: Lockfile Resolution Hijacking in pnpm

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 89/100 | CWE: CWE-345

MITRE ATT&CK: T1195, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm project environment lockfiles are vulnerable to resolution hijacking, allowing them to short-circuit the standard package-manager process and execute arbitrary bytes from a selected location.

Proof of Concept (PoC):

An attacker creates a malicious `pnpm-lock.yaml` file within a shared repository. When a user pulls the code and runs

pnpm, the tool follows the forged instructions in the lockfile to download and execute arbitrary binaries instead of verified packages.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55698>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55698>

CVE-2026-49340

Finding: Arbitrary File Write in gonic

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 83/100 | CWE: CWE-22

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The `createPlaylist` function in gonic allows authenticated users to write M3U content to an arbitrary path on the host system. This vulnerability facilitates unauthorized file creation or modification.

Proof of Concept (PoC):

An authenticated user submits a request to create a playlist with a crafted filename containing path traversal characters. The application writes the playlist data to an attacker-specified path on the host file system instead of the playlist folder.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49340>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49340>

CVE-2026-47424

Finding: RCE via Groovy Sandbox Escape in OpenAM

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-693

MITRE ATT&CK: T1203, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

OpenAM allows authenticated remote code execution via a Groovy sandbox escape vulnerability. An attacker with minimal privileges can execute arbitrary code on the server by bypassing script execution protections.

Proof of Concept (PoC):

An authenticated user sends a script to an endpoint that processes Groovy code. By leveraging specific reflection techniques that are incorrectly restricted in the current sandbox configuration, the attacker escapes the environment to run arbitrary system commands.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-47424>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-47424>

CVE-2026-55697

Finding: Remote Command Execution via pnpm Config

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-78

MITRE ATT&CK: T1059, T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm configuration allows repository-controlled dependencies to force the selection of an arbitrary paquet native install engine, leading to potential command execution during the installation phase.

Proof of Concept (PoC):

A project repository contains a malicious configuration file that defines an alternative native install engine. When pnpm installs the project, it executes the specified engine binary, which the attacker has pointed to malicious code.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55697>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55697>

CVE-2026-55487

Finding: Manifest Spoofing for Arbitrary Lifecycle Execution

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-346

MITRE ATT&CK: T1195, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm manifest identity spoofing allows unauthorized packages to bypass `allowBuilds` security controls. This forces the execution of arbitrary lifecycle scripts, leading to code execution during dependency installation.

Proof of Concept (PoC):

An attacker publishes a package that spoofs its identity to match a trusted dependency in the manifest. pnpm incorrectly authorizes this package to run build scripts, allowing the attacker to execute arbitrary shell commands on the user's machine.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55487>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55487>

CVE-2026-55700

Finding: Arbitrary File Write in pnpm Stage

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	High

Description:

The pnpm package manager suffers from an arbitrary file write vulnerability during the stage download process. Attackers can leverage malicious manifest names to perform directory traversal and overwrite files outside the target directory.

Proof of Concept (PoC):

A developer executes `pnpm install` on a malicious package. The package manifest includes a specially crafted name containing traversal sequences (..) that forces the pnpm installer to write files into sensitive system locations, potentially overwriting configuration files.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55700>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55700>

CVE-2026-49338

Finding: IDOR in Subsonic API Playlist Access

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-285

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Subsonic API fails to properly authorize access to user-owned playlists. Any authenticated user can read or delete the playlists belonging to any other user via an Insecure Direct Object Reference (IDOR) attack.

Proof of Concept (PoC):

An authenticated user identifies the numeric ID of a target playlist. By sending a crafted DELETE or GET request to the Subsonic API with the target's ID, the user bypasses authorization checks and modifies or accesses the remote playlist content.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49338>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49338>

CVE-2026-49339

Finding: Path Traversal in gonic Playlist API

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Gonic is vulnerable to path traversal within the playlist ID parameter. This allows an attacker to bypass ownership checks and manipulate file paths to read or delete arbitrary playlists.

Proof of Concept (PoC):

The attacker sends a request to the gonic API where the playlist ID is manipulated using traversal sequences like `../../../../`. The server resolves these paths outside the intended data directory, allowing the attacker to access files they do not own.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49339>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49339>

CVE-2026-48717

Finding: OAuth Authorization Bypass via PKCE Challenge

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 73/100 | CWE: CWE-285

MITRE ATT&CK: T1136, T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

OpenAM exhibits an authorization bypass flaw involving the handling of PKCE challenges in the OAuth flow. This allows an attacker to manipulate the authentication handshake, potentially resulting in unauthorized token issuance.

Proof of Concept (PoC):

An attacker initiates an OAuth flow and intercepts the authorization request. By crafting a malformed PKCE challenge-verifier pair, the attacker coerces the server into skipping verification steps, successfully obtaining an authorization code for an arbitrary user session.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48717>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48717>

CVE-2026-53523

Finding: Host Header Injection in Nezha OAuth

CVSS v3.1 Score: 6.8 | Severity: Medium | Urgency Score: 71/100 | CWE: CWE-601

MITRE ATT&CK: T1185

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Nezha Monitoring is vulnerable to Host Header Injection within its OAuth2 redirect flow. An attacker can influence the redirect URL, potentially redirecting users to a malicious site to harvest authorization codes.

Proof of Concept (PoC):

The attacker forces a user to click a crafted link containing a malicious `Host` header. The OAuth flow uses the injected host to generate the redirect URI, sending the user and the authorization code to an attacker-controlled server.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53523>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53523>

CVE-2026-55699

Finding: Local File Deletion via pnpm Bin Name

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-22

MITRE ATT&CK: T1485

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	High

Description:

pnpm allows for the deletion of `PNPM\_HOME` during global remove operations due to reserved bin name mishandling. This leads to local denial of service by destroying the global package management directory.

Proof of Concept (PoC):

An attacker convinces a victim to globally install a malicious package. Upon running the uninstall command, the tool triggers a cleanup routine that mistakenly interprets a reserved bin name as an instruction to recursively remove the `PNPM\_HOME` directory.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55699>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55699>

CVE-2026-53522

Finding: WebSocket Resource Exhaustion in Nezha

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Nezha Monitoring allows unbounded WebSocket streams, which can be exploited to exhaust server resources. This leads to a denial of service (DoS) by overloading memory or connection limits.

Proof of Concept (PoC):

An attacker opens a large number of concurrent WebSocket connections to the monitoring service without closing them. The server fails to enforce connection limits or timeouts, consuming resources until it is unable to handle legitimate monitoring traffic.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53522>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53522>

CVE-2026-44840

Finding: DQL Injection in Dgraph GraphQL Queries

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-943

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Dgraph is susceptible to DQL injection via the checkUserPassword GraphQL query endpoint. An attacker can manipulate backend queries to bypass security controls or extract sensitive data from the underlying database, leading to compromised confidentiality.

Proof of Concept (PoC):

An unauthenticated attacker sends a crafted GraphQL mutation containing malicious DQL syntax within the password field. The backend fails to sanitize this input, executing the injected query against the Dgraph store and returning unauthorized information to the attacker.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44840>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44840>

CVE-2026-47426

Finding: OAuth Client Impersonation via JWKS Cache**CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-287**

MITRE ATT&CK: T1550, T1185

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

OpenAM is vulnerable to client impersonation caused by improper validation of the JWKS resolver cache. An attacker can manipulate cached keys to sign illegitimate JWT tokens, effectively masquerading as a legitimate OAuth client.

Proof of Concept (PoC):

The attacker triggers the application to resolve a malicious JWKS endpoint containing a public key controlled by the attacker. By populating the cache, the attacker can then submit tokens signed by their corresponding private key, which OpenAM verifies as valid.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-47426>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-47426>**CVE-2026-53465****Finding: Heap Overflow in ImageMagick SF3 Encoder****CVSS v3.1 Score: 6.2 | Severity: Medium | Urgency Score: 66/100 | CWE: CWE-122**

MITRE ATT&CK: T1203, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	High

Description:

ImageMagick has a heap buffer overflow in the SF3 encoder during multi-frame image processing. Processing a specially crafted image can lead to memory corruption, potentially allowing arbitrary code execution.

Proof of Concept (PoC):

The attacker provides a specially crafted SF3 image file to an application utilizing ImageMagick. The library fails to perform adequate bound checking during the multi-frame write process, causing a heap overflow that crashes the service or enables code injection.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53465>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53465>**CVE-2026-55180****Finding: Environment Secret Exfiltration via pnpm Config**

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-200

MITRE ATT&CK: T1530

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

A vulnerability in pnpm allows repository configuration to expand environment secrets into registry requests. This leads to the unintentional exposure of sensitive environment variables to third-party registries.

Proof of Concept (PoC):

An attacker creates a repository with a configuration file that uses environment variable interpolation in a registry URL. When pnpm runs in a CI/CD environment, it leaks the secret values in the HTTP headers or request body sent to the attacker-controlled registry.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55180>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55180>**CVE-2026-54243****Finding: CSV Formula Injection in Statamic****CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-1236**

MITRE ATT&CK: T1566

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	Low

Description:

Statamic is vulnerable to CSV formula injection in exported form submissions. Attackers can inject malicious spreadsheet formulas into input fields, which execute when a user opens the export in software like Excel.

Proof of Concept (PoC):

The attacker inputs a malicious formula (e.g., `=cmd|' /C calc!A0``) into a public-facing form. When an administrator exports these submissions to CSV and opens the file in Excel, the embedded formula executes on the administrator's local machine.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54243>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54243>**CVE-2026-53464****Finding: Memory Leak in ImageMagick Wand Parser****CVSS v3.1 Score: 4.0 | Severity: Medium | Urgency Score: 46/100 | CWE: CWE-401**

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

A memory leak exists in the ImageMagick Wand option parser when provided with invalid arguments. An attacker can trigger repeated memory allocation failures to cause denial of service.

Proof of Concept (PoC):

The attacker sends a high volume of requests to an ImageMagick-based web application with invalid command-line-style arguments. The parser leaks memory with every request, eventually exhausting system resources and causing the application to crash.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53464>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53464>

CVE-2026-54242

Finding: SSRF via DNS Rebinding in Statamic

CVSS v3.1 Score: 4.9 | Severity: Medium | Urgency Score: 44/100 | CWE: CWE-367

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Statamic's Glide component is vulnerable to Server-Side Request Forgery (SSRF) via DNS rebinding. Attackers can bypass internal network protections to perform unauthorized requests from the server.

Proof of Concept (PoC):

The attacker hosts a malicious domain that initially resolves to a safe IP but quickly switches to an internal IP (e.g., 127.0.0.1). By forcing Statamic's image processor to fetch from this domain, the attacker bypasses filters to interact with internal services.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54242>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54242>

CVE-2026-54244

Finding: Unauthorized Preview Access in Statamic CMS

CVSS v3.1 Score: 3.5 | Severity: Low | Urgency Score: 27/100 | CWE: CWE-863

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Statamic CMS has an authorization flaw allowing view-only users to access Live Preview content, which should be restricted to users with edit permissions. This results in unauthorized disclosure of unpublished sensitive content.

Proof of Concept (PoC):

A user with low-level access submits a crafted request for a draft page preview. The application fails to verify if the user has sufficient permissions to view the draft, exposing potentially sensitive pre-publication content to the user.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54244>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54244>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>